Appendix 5: Information Security

Preamble

Crowdfox GmbH ("Crowdfox") and the Customer conclude a Software-as-a-Service Contract ("Main Contract") and have agreed that this Appendix shall become part of the Main Contract. This Appendix enters into force when the Main Contract becomes effective and does not require a separate signature. Rights and obligations under this Appendix arise only if the Customer has concluded the Main Contract with Crowdfox.

This Appendix describes the technical and organizational measures by which Crowdfox protects Customer Data against loss, unauthorized access, unauthorized disclosure and unauthorized modification. It applies to all Customer Data, irrespective of whether such data constitutes personal data. Where Customer Data constitutes personal data, Appendix 3 (Data Processing Agreement) applies in addition and takes precedence in matters of data protection law.

Table of Contents

I. Definitions 2
II. Information Security Management System 2
III. Organization and responsibilities 2
IV. Personnel security 3
V. Access control 3
VI. Physical security and hosting environment 4
VII. Cryptography 4
VIII. Secure software development 4
IX. Operations, logging and monitoring 5
X. Threat and vulnerability management 5
XI. Backup and business continuity 5
XII. Suppliers and subcontractors 6
XIII. Security incident management 6
XIV. Confidentiality of Customer Data 7
XV. Use of Customer Data 7
XVI. Return and deletion of Customer Data 8
XVII. Evidence and audit 8
XVIII. Changes to the measures 8
XIX. Relationship to the other contract documents 9

I. Definitions

1. "**Customer Data**" means all data, content and information transferred to Crowdfox by the Customer or on the Customer's behalf, or generated by the Customer through use of the Service, and stored or processed by Crowdfox in the course of providing the Service. Customer Data includes non-personal business data such as material master data, pricing and commercial terms, demand and consumption data and supplier information.
2. "**Security Incident**" means a confirmed event that has led to the loss, destruction, unauthorized disclosure of, unauthorized access to, or unauthorized modification of Customer Data. Unsuccessful access attempts, blocked attacks, port scans, failed login attempts, denied network traffic and comparable events which do not affect the confidentiality, integrity or availability of Customer Data are not Security Incidents.
3. "**Service**" means the software provided by Crowdfox as Software-as-a-Service under the Main Contract, as described in Appendix 1 (Description of Services).
4. Terms defined in Appendix 2 (General Terms and Conditions) or Appendix 3 (Data Processing Agreement) have the same meaning in this Appendix unless expressly defined otherwise.

II. Information Security Management System

1. Crowdfox operates a documented Information Security Management System ("ISMS") covering the development and operation of its IT products and services, the associated support and operating processes and the relevant IT systems.
2. The ISMS is certified in accordance with ISO/IEC 27001:2022 by an accredited certification body. Crowdfox shall maintain a valid certification for the term of the Main Contract. Should the certification lapse or its scope be materially reduced, Crowdfox shall inform the Customer in text form.
3. The ISMS is reviewed at least annually by means of an internal audit and a management review, and is subject to external surveillance audits by the certification body.
4. Upon the Customer's reasonable request in text form, Crowdfox shall provide a copy of the current certificate together with the certified scope.

III. Organization and responsibilities

1. Crowdfox has appointed an ISMS coordinator and engages an external Chief Information Security Officer with advisory and supervisory responsibilities. Overall accountability for the ISMS rests with the management of Crowdfox.
2. Crowdfox maintains a documented set of information security policies covering, at minimum: information security governance, asset management and information classification, access control, cryptography, personnel security, physical security, system

and network security, secure development, threat and vulnerability management, supplier and cloud security, business continuity and information security incident management. These policies are approved by management, communicated to all personnel and reviewed at least annually.

3. The security contact for all matters under this Appendix is: security@crowdfox.com.

IV. Personnel security

1. All Crowdfox personnel with access to Customer Data are bound to confidentiality in text form. This obligation survives the end of the employment or contractual relationship for a period of at least three years, and for freelancers at least two years.
2. Crowdfox carries out pre-employment screening in accordance with applicable law. Screening comprises verification of identity for all personnel and verification of qualifications for roles with elevated privileges. Criminal record checks are carried out where legally permissible and appropriate to the role.
3. Crowdfox operates a documented joiner, mover and leaver process. Access rights are granted according to the principle of least privilege upon commencement and are revoked upon termination of the relationship at the latest on the last working day. Shared credentials are rotated and personal API keys and service accounts are revoked.
4. All personnel complete mandatory information security and data protection training upon commencement and at least annually thereafter. Training includes phishing awareness with simulated exercises, and secure development training for engineering personnel. Participation is documented.
5. Crowdfox maintains a documented disciplinary process for violations of its information security policies.

V. Access control

1. Access to systems processing Customer Data is granted on a need-to-know and least-privilege basis, is role-based and is documented in an authorization concept.
2. Multi-factor authentication is mandatory for all administrative, privileged, remote and cloud access. Hardware-based multi-factor authentication is used for the highest-privilege cloud accounts.
3. Passwords are subject to a documented password policy including minimum length and compromise screening, and are managed in an enterprise password manager.
4. Crowdfox reviews and recertifies all access rights, including privileged rights and rights of external parties, at least annually and on an event-driven basis.

5. Administrative access to production systems takes place exclusively via managed, logged access paths. Direct interactive access to production systems requires an approved change record.

VI. Physical security and hosting environment

1. Crowdfox does not operate its own physical server infrastructure. The Service is operated on the infrastructure of professional cloud and hosting providers which are themselves certified in accordance with ISO/IEC 27001 or SOC 2 Type II.
2. Customer Data is stored and processed exclusively within data centers located in the European Union. Any change to this arrangement requires the Customer's prior consent in text form.
3. Physical and environmental security of the data centers, including access control, fire detection and suppression, climate control and uninterruptible power supply, is provided by the respective operator and is covered by that operator's certification.
4. Crowdfox premises are secured against unauthorized access. Crowdfox operates a clean desk policy and prohibits the use of privately owned devices for the processing of Customer Data.

VII. Cryptography

1. Customer Data in transit between the Customer and the Service is protected by transport encryption using TLS version 1.2 as a minimum. The use of unencrypted protocols for the transmission of Customer Data is prohibited.
2. Customer Data at rest is protected by industry-standard encryption, currently AES-256, on storage, database and backup layers. Cryptographic keys are managed in a dedicated key management service with restricted access and periodic key rotation.
3. End-user devices with access to Customer Data are subject to full-disk encryption.
4. Crowdfox reviews the cryptographic algorithms, protocols and key lengths it uses at least annually against recognized standards and adjusts them where required. Keys known or suspected to be compromised are rotated without undue delay.

VIII. Secure software development

1. Crowdfox operates separate development, staging and production environments.
2. Changes to the Service are subject to mandatory peer review by a second qualified person before being merged.
3. The build pipeline includes automated static application security testing, software composition and dependency analysis, secret detection and container image scanning. Findings above a defined severity threshold block the build.

4. Crowdfox maintains a software bill of materials for each release.
5. Deployments to production are automated and version-controlled. Changes are subject to a documented change management process including approval and rollback planning.
6. Crowdfox applies commercially reasonable measures to ensure that the Service does not contain malicious code, and does not knowingly introduce into the Service any code intended to impair its operation, to disable it after a period of time, or to permit unauthorized access to it.

IX. Operations, logging and monitoring

1. Crowdfox operates network segmentation, host-based and network-based protective measures, endpoint protection on all managed devices and a web application firewall in front of the Service.
2. Security-relevant events, including administrative activity, authentication events and infrastructure changes, are logged. Logs are protected against modification and deletion and are retained for a defined period appropriate to their purpose, in the case of infrastructure audit logs for at least twelve months.
3. Crowdfox operates continuous security monitoring of its production environment with defined alerting and escalation paths.
4. Crowdfox operates measures to prevent unintended disclosure of Customer Data, including secret scanning in source code repositories and controls preventing public exposure of storage resources.

X. Threat and vulnerability management

1. Crowdfox operates a documented threat and vulnerability management process. Vulnerabilities are assessed on the basis of their severity, in particular using CVSS, and are remediated within risk-based target timeframes defined in that process, with critical vulnerabilities prioritized.
2. The production environment and the Service are subject to continuous automated vulnerability scanning, including infrastructure scanning, dependency scanning at commit level and configuration benchmarking.
3. Penetration testing of the production environment by the Customer or by third parties engaged by the Customer is permissible only on the basis of a separate agreement in text form covering scope, method, time window, liability and allocation of costs.

XI. Backup and business continuity

1. Crowdfox backs up Customer Data at least daily. Backups are encrypted, are stored separately from the primary system and are retained for at least 30 days.

2. The recoverability of backups is verified by restore tests at least twice per contract year. Results are documented.

3. Crowdfox maintains a documented business continuity and disaster recovery plan for the Service, defining recovery time and recovery point objectives, responsibilities, escalation paths and communication procedures. The plan is tested at least annually. Upon the Customer's reasonable request in text form, Crowdfox shall inform the Customer of the recovery objectives applicable to the Service.

XII. Suppliers and subcontractors

1. Crowdfox may engage subcontractors for the provision of the Service. Crowdfox shall impose on such subcontractors obligations equivalent in substance to those set out in this Appendix and shall remain responsible for their performance in accordance with Appendix 2.

2. Subcontractors with access to Customer Data are subject to a documented supplier security assessment prior to engagement and are reviewed at least annually. Subcontractors classified as critical must demonstrate certification in accordance with ISO/IEC 27001 or SOC 2 Type II.

3. Subcontractors are contractually obliged to report security incidents affecting Crowdfox data without undue delay.

4. Upon the Customer's reasonable request in text form, Crowdfox shall provide a current list of the subcontractors engaged in the provision of the Service. Where such subcontractors process personal data, the procedure set out in Appendix 3 Section IX applies in addition.

XIII. Security incident management

1. Crowdfox operates a documented information security incident management process comprising detection, classification, containment, remediation, communication and post-incident review, with defined severity classes and internal response times.

2. Crowdfox shall notify the Customer of a Security Incident affecting that Customer's Customer Data in text form without undue delay and at the latest within 48 hours of Crowdfox having confirmed the Security Incident. Notification shall be sent to the contact designated by the Customer for this purpose.

3. The notification under XIII. 2 shall contain the information available to Crowdfox at that time. Crowdfox shall provide the following information as soon as it becomes available, and at the latest within five business days of the notification: a description of the Security Incident, the categories of Customer Data affected as far as known, the measures taken to contain it and the measures taken or planned to mitigate its effects.

4. Crowdfox shall assess each Security Incident within its risk management process and shall implement appropriate corrective measures. Crowdfox shall inform the Customer of the outcome upon request. The determination of the appropriate corrective measures within Crowdfox's own environment rests with Crowdfox.
5. Crowdfox shall reasonably cooperate with the Customer in the investigation of a Security Incident affecting the Customer's Customer Data. Notification under this Section does not constitute an acknowledgment of fault or liability.
6. Where a Security Incident also constitutes a personal data breach, Appendix 3 Section XI applies in addition.

XIV. Confidentiality of Customer Data

1. Crowdfox shall treat Customer Data as confidential, shall use it exclusively for the purposes of performing the Main Contract and shall not disclose it to third parties, except to subcontractors engaged in accordance with Section XII or where disclosure is required by law, court order or order of a public authority.
2. Where disclosure is legally required, Crowdfox shall, to the extent legally permissible, inform the Customer in advance and shall limit the disclosure to the legally required extent.
3. The exceptions set out in Appendix 2 Section I.3.c apply accordingly.
4. Crowdfox operates a documented information classification scheme and applies protective measures corresponding to the classification of the information concerned.

XV. Use of Customer Data

1. Crowdfox processes Customer Data exclusively for the purpose of providing, operating, securing, maintaining and supporting the Service, and otherwise only on the Customer's instruction.
2. Crowdfox does not use Customer Data to train, fine-tune or otherwise improve artificial intelligence or machine learning models of third parties and does not disclose Customer Data to third-party providers of such models for that purpose.
3. Crowdfox remains entitled to generate and use aggregated, statistical and anonymized information derived from the operation of the Service for the purposes of operating, securing, analyzing and further developing the Service, provided that such information does not permit any conclusion to be drawn about the Customer, its personnel, its suppliers or its commercial terms, and that it is not disclosed to third parties in a form attributable to the Customer.
4. Crowdfox does not use Customer Data for competitive benchmarking naming the Customer or its commercial terms.

XVI. Return and deletion of Customer Data

1. During the term of the Main Contract, the Customer may export the Customer Data stored in the Service using the export functions provided by the Service.
2. Upon expiry or termination of the Main Contract, Crowdfox shall delete the Customer Data. The Customer is responsible for securing the Customer Data it wishes to retain before the end of the period of use. Deletion from backup media takes place in accordance with the applicable backup rotation cycle. Statutory retention obligations remain unaffected.
3. Upon the Customer's request in text form, Crowdfox shall confirm the deletion in text form.

XVII. Evidence and audit

1. Crowdfox shall demonstrate compliance with the obligations set out in this Appendix by providing suitable evidence. Suitable evidence comprises in particular the current ISO/IEC 27001 certificate including the certified scope, the certification reports of the cloud and hosting providers used and a completed security questionnaire in Crowdfox's own standard format.
2. Upon the Customer's reasonable request in text form, and not more than once per contract year, Crowdfox shall provide the evidence set out in XVII. 1.
3. An on-site inspection at Crowdfox's premises may be requested by the Customer only if Crowdfox no longer maintains a valid ISO/IEC 27001 certification or following a Security Incident affecting the Customer's Customer Data. Any such inspection shall take place not more than once per contract year, during normal business hours, upon at least 30 days' prior notice, subject to a confidentiality undertaking, without disruption to operations, and shall not extend to data, systems or information of other customers of Crowdfox. The Customer shall bear its own costs and the costs of any inspector it engages; Crowdfox's expenditure shall be remunerated on a time and materials basis.
4. Crowdfox may object to an inspector engaged by the Customer for good cause, in particular where that inspector is a competitor of Crowdfox.
5. Beyond the obligations expressly set out in this Appendix, Crowdfox owes no proactive reporting, notification, certification or documentation obligations. Documents and information shall be provided upon request in accordance with this Section XVII.

XVIII. Changes to the measures

1. The measures described in this Appendix reflect the state of the art at the time of conclusion of the Main Contract and are subject to ongoing technical development. Crowdfox is entitled to adapt, replace or supplement individual measures, provided that the level of protection achieved is not reduced below the level described in this Appendix.

2. The version of this Appendix current at any time is available to the Customer upon request.

XIX. Relationship to the other contract documents

1. This Appendix supplements Appendix 2 (General Terms and Conditions), Appendix 3 (Data Processing Agreement) and Appendix 4 (Service Level Agreement). In the event of conflict, Appendix 3 takes precedence in matters of data protection law and Appendix 4 takes precedence in matters of availability and service levels. In all other respects the Main Contract and Appendix 2 take precedence over this Appendix.
2. This Appendix does not establish any liability going beyond Appendix 2 Section I.4, does not constitute a guarantee or a warranted characteristic within the meaning of that Section, and does not establish any service levels, availability commitments or contractual penalties.
3. Security policies, standards, control catalogs, questionnaires or audit requirements of the Customer or of companies affiliated with the Customer do not become part of the contract. They become binding only where Crowdfox has expressly agreed to them in text form and their implementation has been separately remunerated.
4. Should individual provisions of this Appendix be or become invalid, the validity of the remaining provisions shall remain unaffected.

Crowdfox GmbH
Kaiser-Wilhelm-Ring 40
50672 Cologne
CEO: Dirk Schäfer

Phone / Mail / Web:
+49 221 292 723 82
welcome@crowdfox.com
www.crowdfox.pro

Bank:
Commerzbank Bergisch Gladbach
IBAN: DE42370400440277726600
BIC: COBADEFFXXX

Tax Number: DE297246515
Registered: Local court of Cologne, Germany, under HRB 81982